

Modelo de Encuesta Integral

GDPR – Ciberseguridad, Riesgo y Métricas

Objetivo: esta encuesta pretende medir el grado de madurez de su organización en la aplicación práctica del RGPD en materia de seguridad del tratamiento (arts. 24, 25, 28, 32, 33 y 34), así como la alineación con NIS2, ISO 27001 e ISO 27701 y las expectativas regulatorias (AEPD, EDPB, ENISA). No buscamos confesiones ni catarsis, sino datos: el psicoanálisis vendrá después, con el informe.

Antes de comenzar, indique el tipo de organización:

- ☐ Administración pública
- ☐ Empresa privada – gran organización (≥ 250 empleados)
- ☐ Empresa privada – pyme
- ☐ Entidad financiera
- ☐ Entidad sanitaria
- ☐ Proveedor de servicios digitales / cloud
- ☐ Otro (especificar): _____

1. Gobernanza, responsabilidad proactiva y alcance

1.1. Existencia de modelo de gobierno de privacidad y seguridad

1.1.1. ¿Dispone la organización de un modelo formal de gobierno de protección de datos y seguridad de la información, aprobado por el máximo órgano directivo?

- ☐ No existe nada formal; vivimos en el “management by susto”.
- ☐ Existen políticas dispersas sin aprobación formal de la alta dirección.
- ☐ Existe política marco aprobada, pero sin un modelo claro de roles y comités.
- ☐ Existe modelo formal (política marco, comité, roles definidos) y se reúne al menos trimestralmente.
- ☐ Modelo formal consolidado, con reporting periódico al consejo/órgano equivalente.

1.1.2. ¿Qué figuras se encuentran designadas formalmente?

- ☐ Delegado de Protección de Datos (DPD/DPO)
- ☐ Responsable de Seguridad de la Información (CISO / RSI)
- ☐ Responsable de Continuidad de Negocio
- ☐ Comité de Seguridad / Comité de Privacidad
- ☐ Ninguna de las anteriores (o todas son “hobbies” del administrador de sistemas)

1.1.3. ¿Con qué frecuencia se presenta información sobre riesgos y métricas de seguridad/privacidad al máximo órgano de gobierno?

- ☐ Nunca (las malas noticias no suben plantas).
- ☐ Solo ad hoc, tras incidentes relevantes.
- ☐ Al menos una vez al año.
- ☐ Semestralmente.
- ☐ Trimestralmente o más.

1.2. Alcance de tratamientos y cartografía

1.2.1. ¿Dispone la organización de un registro actualizado de actividades de tratamiento (ROPA) que incluya referencias a medidas de seguridad?

- ☐ No.
- ☐ En elaboración perpetua.
- ☐ Sí, pero sin referencia sistemática a medidas de seguridad.
- ☐ Sí, con descripción básica de medidas técnicas y organizativas.
- ☐ Sí, y se vincula a análisis de riesgo / EIPD de forma sistemática.

1.2.2. ¿Con qué frecuencia se revisa y actualiza el ROPA?

- ☐ Nunca (es una cápsula del tiempo).
- ☐ Solo antes de auditorías/inspecciones.
- ☐ Cuando se detectan cambios significativos.
- ☐ Anualmente.
- ☐ Cada seis meses o menos.

2. Gestión del riesgo, EIPD y enfoque basado en el riesgo

2.1. Metodología de gestión de riesgos

2.1.1. ¿Existe una metodología formal de análisis y gestión de riesgos aplicable a los tratamientos de datos personales?

- ☐ No, se actúa por intuición y titulares de prensa.
- ☐ Sí, pero solo para riesgos “IT” genéricos, no específicos de privacidad.
- ☐ Sí, específica para privacidad, pero no alineada con marcos internacionales.
- ☐ Sí, alineada con ISO 27005 / ENISA / similares e integrada en el SGSI.
- ☐ Sí, integrada con gestión integral de riesgos corporativos (ERM) y reportada al consejo.

2.1.2. ¿Qué escalas de impacto se utilizan para valorar el riesgo sobre los derechos y libertades?

- ☐ No se utiliza escala formal.
- ☐ Escala cualitativa básica (bajo / medio / alto).
- ☐ Escala cualitativa con criterios definidos por tipo de impacto (económico, reputacional, derechos).
- ☐ Escala cuantitativa o semicuantitativa con rangos documentados.
- ☐ Modelo integrado que vincula impacto en derechos con indicadores económicos y regulatorios.

2.1.3. ¿Qué porcentaje aproximado de tratamientos dispone de análisis de riesgos documentado?

- ☐ 0–25 %
- ☐ 26–50 %
- ☐ 51–75 %
- ☐ 76–95 %
- ☐ 96–100 %

2.2. Evaluaciones de impacto en protección de datos (EIPD / DPIA)

2.2.1. ¿Dispone de un procedimiento formal para determinar cuándo es necesaria una EIPD?

- ☐ No.
- ☐ Sí, pero no se aplica de forma sistemática.
- ☐ Sí, basado exclusivamente en las listas de la AEPD/autoridades.
- ☐ Sí, basado en listas de autoridades y criterios propios de riesgo.
- ☐ Sí, integrado con procesos de innovación y gestión de proyectos (privacy by design).

2.2.2. De los tratamientos que han requerido EIPD, ¿qué porcentaje aproximado se ha completado en los últimos 3 años?

- ☐ 0–25 %
- ☐ 26–50 %
- ☐ 51–75 %
- ☐ 76–95 %
- ☐ 96–100 %

2.2.3. ¿Se actualizan las EIPD tras incidentes o cambios relevantes en el tratamiento o en el contexto de amenazas?

- ☐ No.
- ☐ Solo tras incidentes graves.
- ☐ Sí, para cambios significativos en tecnología o alcance.
- ☐ Sí, para cambios significativos y periódicamente (al menos cada 2 años).
- ☐ Sí, con ciclos de revisión definidos y alineados con la gestión de riesgos corporativos.

3. Medidas técnicas y organizativas (art. 32 RGPD)

3.1. Cifrado, pseudonimización y controles de acceso

3.1.1. ¿Cuenta la organización con una política formal de cifrado alineada con las directrices de la AEPD/ENISA?

- ☐ No existe política de cifrado.
- ☐ Existe una política, pero no se aplica de forma coherente.
- ☐ Existe política alineada con buenas prácticas básicas.
- ☐ Existe política alineada con guías de AEPD/ENISA y estándares sectoriales.
- ☐ Política madura con niveles de criticidad, algoritmos validados y ciclo de revisión regular.

3.1.2. ¿Qué porcentaje aproximado de datos personales en reposo está cifrado con mecanismos considerados robustos?

- ☐ 0-25 %
- ☐ 26-50 %
- ☐ 51-75 %
- ☐ 76-95 %
- ☐ 96-100 %

3.1.3. ¿Qué porcentaje aproximado de datos personales en tránsito está protegido mediante canales cifrados (TLS u otros)?

- ☐ 0-25 %
- ☐ 26-50 %
- ☐ 51-75 %
- ☐ 76-95 %
- ☐ 96-100 %

3.1.4. ¿Qué nivel de implantación tiene la autenticación multifactor (MFA) en sistemas que tratan datos personales?

- ☐ No se utiliza MFA.
- ☐ MFA solo en accesos remotos / VPN.
- ☐ MFA en sistemas críticos internos y accesos remotos.
- ☐ MFA en la mayoría de sistemas que tratan datos personales.
- ☐ MFA por defecto, con excepciones justificadas y documentadas.

3.1.5. ¿Se aplican técnicas de pseudonimización para minimizar exposición en entornos de pruebas, analítica o intercambio de datos?

- ☐ No se utiliza pseudonimización.
- ☐ Uso ad hoc en algunos proyectos.
- ☐ Uso regular en pruebas, pero no en analítica.
- ☐ Uso sistemático en pruebas y entornos de analítica interna.
- ☐ Uso avanzado, incluyendo entornos colaborativos y espacios de datos.

3.2. Segmentación, monitorización y hardening

3.2.1. ¿Existe segmentación lógica o física de redes que separa entornos críticos con datos personales?

- ☐ No.
- ☐ Segmentación básica entre entornos de producción y otros.
- ☐ Segmentación por zonas de criticidad (usuarios, servidores, datos sensibles).
- ☐ Segmentación granular con controles de acceso y monitorización avanzada.
- ☐ Modelo Zero Trust con segmentación dinámica basada en identidad y contexto.

3.2.2. ¿Se encuentran los sistemas que tratan datos personales bajo monitorización continua (SIEM/SOC u otros)?

- ☐ No hay monitorización.
- ☐ Monitorización básica, logs locales sin correlación.
- ☐ SIEM limitado a sistemas críticos.
- ☐ SIEM/SOC para la mayoría de sistemas relevantes.
- ☐ SOC maduro, con análisis avanzado de comportamiento y modelos basados en IA.

3.2.3. Tiempo medio de aplicación de parches de seguridad críticos en sistemas que tratan datos personales (promedio último año):

- ☐ > 90 días
- ☐ 61–90 días
- ☐ 31–60 días
- ☐ 8–30 días
- ☐ ≤ 7 días

3.2.4. ¿Se aplica un proceso de hardening documentado a servidores, estaciones de trabajo y dispositivos móviles que tratan datos personales?

- ☐ No.
- ☐ Solo en algunos servidores.
- ☐ Sí, en servidores y equipos de administración.
- ☐ Sí, en servidores, estaciones de trabajo y dispositivos móviles corporativos.
- ☐ Sí, con verificación periódica automatizada de cumplimiento de hardening.

4. Notificación de brechas (arts. 33 y 34 RGPD)

4.1. Preparación y procesos

4.1.1. ¿Existe un procedimiento formal y probado de gestión de incidentes y brechas de datos personales?

- ☐ No.
- ☐ Existe un procedimiento escrito, pero nunca se ha probado.
- ☐ Se ha probado al menos una vez (simulacro).
- ☐ Se realizan simulacros anuales.
- ☐ Se realizan simulacros al menos dos veces al año, incluyendo escenarios complejos y con terceros.

4.1.2. ¿Dispone de un registro sistemático de incidentes que permita diferenciar entre “incidente de seguridad” y “brecha de datos personales”?

- ☐ No.
- ☐ Registro parcial en herramientas técnicas.
- ☐ Registro centralizado pero sin tipología detallada.
- ☐ Registro con tipología RGPD y campos estructurados.
- ☐ Registro integrado con métricas, análisis de causa raíz y lecciones aprendidas.

4.2. Métricas de incidentes y brechas

4.2.1. Número de brechas de datos personales notificadas a la autoridad de control en los últimos 12 meses:

- ☐ 0
- ☐ 1-3
- ☐ 4-10
- ☐ 11-25
- ☐ > 25
- ☐ Prefiero no responder en un documento que puede ser utilizado en mi contra.

4.2.2. En las brechas notificadas, el tiempo medio hasta la detección se sitúa en:

- ☐ > 30 días
- ☐ 8-30 días
- ☐ 3-7 días
- ☐ < 72 horas
- ☐ Desconocido (lo que ya es, en sí mismo, un indicador).

4.2.3. En las brechas notificadas, el tiempo medio hasta la notificación a la autoridad fue:

- ☐ > 72 horas, sin justificación documentada.
- ☐ > 72 horas, con justificación documentada.
- ☐ Dentro de las 72 horas, con margen apurado.
- ☐ Dentro de las 48 horas.
- ☐ Dentro de las 24 horas.

4.2.4. Porcentaje aproximado de brechas en las que las medidas técnicas (cifrado, pseudonimización, segmentación) limitaron efectivamente el impacto sobre los afectados:

- ☐ 0–25 %
- ☐ 26–50 %
- ☐ 51–75 %
- ☐ 76–95 %
- ☐ 96–100 %

5. Relación con terceros, nube y cadena de suministro (arts. 28 y 32)

5.1. ¿Dispone de un proceso formal para evaluar la seguridad y el cumplimiento RGPD de encargados del tratamiento y proveedores críticos (incluyendo cloud)?

- ☐ No, confiamos en el “buen hacer” del proveedor.
- ☐ Evaluación solo contractual (cláusulas tipo, DPA estándar).
- ☐ Cuestionarios básicos de seguridad y privacidad al inicio de la relación.
- ☐ Evaluaciones periódicas con cuestionarios estructurados y evidencias.
- ☐ Proceso maduro con evaluación continua, certificaciones, auditorías y métricas de desempeño.

5.2. Porcentaje aproximado de proveedores que manejan datos personales que cuentan con certificaciones relevantes (ISO 27001, ISO 27701, SOC 2, etc.):

- ☐ 0–25 %
- ☐ 26–50 %
- ☐ 51–75 %
- ☐ 76–95 %
- ☐ 96–100 %

5.3. ¿Se monitoriza de forma continua la postura de seguridad de proveedores clave (herramientas de “security rating”, informes externos, etc.)?

- ☐ No.
- ☐ Solo en el momento de la contratación.
- ☐ Revisión anual.
- ☐ Revisión semestral con fuentes externas.
- ☐ Monitorización continua con herramientas especializadas y seguimiento en comité.

6. Formación, cultura y competencia

6.1. ¿Qué nivel de formación en protección de datos y ciberseguridad reciben los empleados que tratan datos personales?

- ☐ Ninguna formación específica.
- ☐ Formación inicial al incorporarse, sin refrescos.
- ☐ Formación inicial + refresco bianual.
- ☐ Formación anual obligatoria con seguimiento de completitud.
- ☐ Formación continua con módulos específicos por rol y simulaciones (phishing, ejercicios, etc.).

6.2. Porcentaje aproximado de empleados que han completado la formación obligatoria en el último año:

- ☐ 0–25 %
- ☐ 26–50 %
- ☐ 51–75 %
- ☐ 76–95 %
- ☐ 96–100 %

6.3. ¿Se dispone de métricas de comportamiento (tasa de clic en phishing simulado, reporte de incidentes por usuario, etc.)?

- ☐ No.
- ☐ Métricas limitadas y no sistemáticas.
- ☐ Métricas de phishing simulado.
- ☐ Métricas de phishing y reporte de incidentes por usuario.
- ☐ Cuadro de mando completo de comportamiento seguro, integrado en el cuadro de riesgos.

7. Indicadores, métricas y cuadro de mando

7.1. ¿Dispone la organización de un cuadro de mando formal de ciberseguridad y protección de datos?

- ☐ No.
- ☐ Sí, pero centrado solo en TI.
- ☐ Sí, con indicadores básicos (nº incidentes, formación).
- ☐ Sí, con indicadores de riesgo, procesos, incidentes y cumplimiento RGPD.
- ☐ Sí, integrado con indicadores de negocio, continuidad y riesgo corporativo.

7.2. ¿Qué indicadores se reportan regularmente a la dirección? (marque todos los que apliquen)

- ☐ Número de incidentes de seguridad.
- ☐ Número de brechas de datos personales.
- ☐ Tiempo medio de detección y respuesta.
- ☐ Nivel de cifrado / cobertura de medidas técnicas.
- ☐ Avance de EIPD / análisis de riesgos.
- ☐ Cumplimiento de formación.
- ☐ Sanciones o investigaciones de autoridades.
- ☐ Indicadores de proveedores y cadena de suministro.

7.3. ¿Dispone de métricas de madurez alineadas con modelos como NIS2, ISO 27001 o ISO 27701?

- ☐ No.
- ☐ Evaluación puntual de madurez.
- ☐ Evaluaciones periódicas (cada 2–3 años).
- ☐ Evaluaciones anuales con plan de mejora.
- ☐ Evaluaciones continuas, con metas y seguimiento en comités de riesgo.

7.4. ¿Se calculan indicadores económicos tales como coste de incidentes, inversión en medidas de seguridad y retorno de la inversión (ROI) de proyectos de cumplimiento?

- ☐ No.
- ☐ Solo coste aproximado de incidentes graves.
- ☐ Coste de incidentes y presupuesto de seguridad.
- ☐ Coste de incidentes, inversión y estimación de ahorro por mitigación.
- ☐ Modelo formal de ROI y TCO de seguridad y cumplimiento, ligado a decisiones de inversión.

8. Resultados regulatorios y relaciones con autoridades

8.1. En los últimos 3 años, ¿ha recibido la organización sanciones o apercibimientos relativos a seguridad del tratamiento, brechas o deficiencias de medidas?

- ☐ No.
- ☐ Sí, apercibimientos sin multa.
- ☐ Sí, sanciones económicas inferiores a 100.000 €.
- ☐ Sí, sanciones entre 100.000 € y 1.000.000 €.
- ☐ Sí, sanciones superiores a 1.000.000 €.

8.2. ¿Ha sido objeto de investigaciones transfronterizas (mecanismo de ventanilla única – OSS)?

- ☐ No.
- ☐ Sí, como responsable principal.
- ☐ Sí, como interesado en investigación iniciada por otra autoridad.
- ☐ Sí, en múltiples ocasiones.

8.3. Tras incidentes o sanciones, ¿se han incorporado métricas específicas de seguimiento (KPIs de remediación)?

- ☐ No se han definido métricas específicas.
- ☐ Se han definido acciones, pero sin indicadores asociados.
- ☐ Se han definido algunos indicadores ad hoc.
- ☐ Existe un conjunto definido de KPIs de remediación con seguimiento periódico.
- ☐ Los KPIs de remediación se integran en el cuadro de mando general y se reportan a la alta dirección.

9. Innovación, IA y nuevos contextos de riesgo

9.1. ¿Utiliza la organización sistemas de IA o analítica avanzada que impliquen tratamientos de datos personales?

- ☐ No.
- ☐ Sí, pero de forma incipiente.
- ☐ Sí, en procesos internos.
- ☐ Sí, en productos/servicios ofrecidos a clientes/ciudadanos.
- ☐ Sí, de manera extensiva y estratégica.

9.2. Para esos sistemas de IA, ¿se han realizado análisis de impacto específicos (EIPD) y se han derivado controles y métricas concretas?

- ☐ No.
- ☐ Se está evaluando cómo hacerlo.
- ☐ Sí, con análisis de impacto básico.
- ☐ Sí, con análisis detallado y métricas de riesgo/eficacia de controles.
- ☐ Sí, integrado con marcos de IA responsable y gobernanza de algoritmos.

10. Comentarios finales

10.1. Señale brevemente cuáles considera que son los principales retos de su organización en materia de seguridad del tratamiento y métricas de cumplimiento:

10.2. Si pudiera añadir un indicador “imposible pero perfecto” para medir el cumplimiento RGPD en seguridad, ¿cuál sería?